



Challenges in regulating cloud service providers in EU financial regulation: From operational to systemic risks, and examining challenges of the new oversight regime for critical cloud service providers under the Digital Operational Resilience Act

Eyup Kun

Doctoral Researcher at Centre for IT & IP Law (CiTiP), (Supervisor: Prof. Peggy Valcke) - IMEC, KU, Leuven, Belgium

ARTICLE INFO

Keywords:

Systemic risk
DORA
Operational risk
Cloud services
Cybersecurity risk

ABSTRACT

The use of cloud services by financial institutions has become increasingly prevalent due to its economic benefits. However, this comes with the inherent drawbacks of increased security risks and potential financial stability risks from the cloud market concentration. The EU has introduced specific legal instruments that place responsibilities on financial institutions to mitigate these risks. This paper analyses how the regulation of cloud service providers in the EU financial sector has evolved from the regulation of operational risk to the regulation of systemic risk. The Digital Operational Resilience Act, adopted in December 2022 and effective from January 17, 2025, plays a key role in enabling this transformation by recognizing the systemic risk aspect of the use of cloud service providers. It responds to this risk by creating a new oversight regime of critical cloud service providers. However, new oversight of critical cloud service providers brings about novel problems, particularly concerning the *ne bis in idem* principle in the case of overlapping oversight and enforcement by different authorities responsible for respective legislative instruments in cybersecurity and data protection. The overlapping oversight shall respect the principle. This paper evaluates to what extent the overlapping regime respects the principle under Article 50 of the Charter of Fundamental Rights of the European Union by analysing the Digital Operational Resilience Act and provides suggestions to improve coordination among different competent authorities in the case of overlapping supervision and enforcement to respect the principle.

1. Introduction

Financial institutions (FIs) rely heavily on technology to function, which is generally deployed on their local computer infrastructure. However, technological progress has accelerated dramatically, requiring FIs to embrace the advancement.¹ The finance industry is widely recognised as one of the most digitised sectors within the broader economy. The processes of digitisation involve the conversion of analogical information into digital form. These processes have had a profound impact on the financial industry. The integration of emerging data-intensive technologies, such as artificial intelligence and blockchain, has resulted in a strong interconnection between finance and data. Financial

transactions involve the transfer of data, while financial infrastructures, such as stock exchanges and payment systems, can be understood as data networks.

Financial regulation has been compelled to evolve in response to financial digitalisation. Simultaneously, new sets of rules and principles have been developed to assert control over the digital world. These regulations are increasingly encompassing all critical societal functions, ranging from privacy to national security.² However, the convergence of financial regulation, new regulatory frameworks for digital finance, and general data governance regimes are not always clear.³ Conflicts arising from the intersection of disparate and uncoordinated regimes threaten to undermine core policy objectives of stability, integrity, and security,

E-mail address: eyup.kun@kuleuven.be.

¹ Vittoria Barbieri, 'EBF Cloud Banking Forum Releases Three Technical Papers' (EBF, 9 June 2020) <<https://www.ebf.eu/innovation-cybersecurity/ebf-cloud-banking-forum-releases-three-technical-papers/>> accessed 7 February 2023.

² Douglas W Arner, Giuliano G Castellano and Eriks Selga, 'Financial Data Governance: The Datafication of Finance, the Rise of Open Banking and the End of the Data Centralization Paradigm' (1 February 2022) <<https://papers.ssrn.com/abstract=4040604>> accessed 5 September 2023.

³ *ibid.*

as well as the operation of the global financial system.⁴

Within the broader context mentioned above, this article limits its scope to the use of cloud computing by FIs since cloud computing⁵ has emerged as a critical technology to process data for developing new financial services, innovating, collaborating with third parties, and competing in the digital context. Banks, for example, are deploying cloud services in a variety of ways, ranging from on-premises private clouds to hosted, managed private clouds and public clouds as infrastructure as a service (IaaS),⁶ platform as a service (PaaS)⁷ or software as a service (SaaS).⁸ According to Cloud Path Survey 2021, 79 % of the global bank executives polled claim to be using public cloud services and 77 % indicate using private cloud services, if only for one or two applications.⁹ All three big cloud companies, namely Amazon,¹⁰ Microsoft,¹¹ and Google¹² offer specific cloud services to organizations in the financial sector. Google, for example, offers a wide range of cloud-based services, including open banking, high-performance computing for risk simulation, and regulatory reporting. PayPal and Deutsche Bahn, according to the Google Cloud website, work closely with Google Cloud to obtain services.

There are a variety of benefits to using cloud service providers (CSPs) in the financial sector. According to the Cloud Path Survey 2021, bank executives see the real benefits of cloud-based operations in terms of their greater business agility and resiliency to respond to market demands.¹³ With open banking APIs, banks can reach customers through new digital distribution channels and deliver innovative products and services. This enables banks to drive innovation and digital transformation more quickly and comprehensively according to bank executives. Moving to the cloud is also seen as a way to improve the customer experience, as it offers new functionalities that improve customer

experience and ultimately enhance satisfaction.¹⁴ The European Banking Federation working paper details the cost-efficiency of the use of cloud services.¹⁵ According to this paper, traditional on-premises IT infrastructure necessitates upfront capital expenditure (CAPEX) by a company to reap future benefits, such as asset acquisition, which must be designed for the maximum workload. The system will not be ready until the project is completed, and large upfront payments are required. Using cloud-based technology, banks can instantly add or remove resources, adapting IT resources to the business's needs through a pay-per-use model. As a result, IT operations can shift from CAPEX to operational expenditure (OPEX), which is incurred for business operations. CAPEX and OPEX are treated differently in tax and accounting. Fixed costs become variable as a result of OPEX. This boosts competitiveness, response times, and use case implementation.

The use of cloud services by FIs may also introduce new risks to the data that is processed by the CSPs.¹⁶ These risks differ depending on the properties of information security: confidentiality, integrity, and availability. These security risks are exacerbated by the fact that cyber attackers seem to consider the cloud service infrastructure as an initial point of access to the data of different companies that use the cloud services.¹⁷ Regarding the confidentiality aspect, which is related to unauthorized access, the risks stem from the specific technological attributes of cloud computing. Because of the multi-tenancy, other customers that use the same resources could have access to the same computing environment. Thus, if the same resources are used by other companies and FIs, it could allow unauthorized parties to access financial institutions' data.¹⁸ CSPs mitigate the risk by virtually segregating workloads and data by using techniques such as firewalls or encryption and preventing unauthorized access at the hardware level.¹⁹ Regarding the integrity aspects, the integrity of data, which protects it from unauthorized destruction, loss, or modification, is dependent on access and systems. Preventing unauthorized access to maintain integrity raises the same concerns as preventing access to maintain confidentiality. For example, application errors may result in data corruption or inadvertent deletion. Cloud data may be physically located in multiple sets of equipment, possibly even different data centres because CSPs can back up or replicate data to ensure integrity.²⁰ Regarding the availability aspect, if providers do not protect their infrastructures, for instance, against distributed denial-of-service (DDoS) attacks which flood networks and reduce availability, it can lead to significant disruptions. The following examples provide how the security risks of CSPs cause the risk to FIs. According to the incidents reported from January 2016 to July 2017, seven incidents were caused by CSPs, affecting multiple regulated firms, with three of them being caused by a single SaaS provider.²¹ A major Amazon Web Services (AWS) outage can affect multiple businesses at the same time. Since 2011, AWS has experienced four incidents regarding the availability of its services. Multiple online financial

⁴ *ibid.*

⁵ The National Institute of Standards and Technology ('NIST') states that "on-demand self-service," "broad network access," "resource pooling," "rapid elasticity," and "measured service" make a "computing capacity" a "cloud service". See Eric Simmon, 'Evaluation of Cloud Computing Services Based on NIST SP 800-145' (National Institute of Standards and Technology 2018) NIST SP 500-322 <<http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.500-322.pdf>> accessed 9 January 2023. See also for the analysis of these elements, W Kuan Hon, Christopher Millard and Jatinder Singh, 'Control, Security, and Risk in the Cloud', *Cloud Computing Law* (2nd edn, Oxford University Press 2021) <<https://oxford.universitypressscholarship.com/10.1093/oso/9780198716662.001.0001/oso-9780198716662-chapter-2>> accessed 26 July 2022.

⁶ IaaS provides the founding infrastructure, such as a server, from which 'tenants' manage their applications and much of the underlying 'technical stack'. This means that, in general, IaaS involves relatively low-level (i.e. more technical/infrastructure-oriented) functionality for customers, which requires greater sophistication and expertise to use, including more hands-on resource management. See for further analysis, Kuan Hon, Millard and Singh (n 5).

⁷ PaaS provides the technical "building blocks" for supporting and deploying applications, such as various services that can underpin and support application functionality. PaaS customers are relieved of the need to actively manage raw processing/storage resources. See for further analysis, *ibid.*

⁸ SaaS offers higher-level (i.e. more application/user-oriented) functionality, typically through pre-built (though often configurable) applications, and thus requires far less technical expertise to use, but offers less customer control. See for further analysis *ibid.*

⁹ 'Industry CloudPath 2021: Executive Summary Report' (IDC: The premier global market intelligence company) <<https://www.idc.com/getdoc.jsp?containerId=US48119621>> accessed 7 February 2023.

¹⁰ 'Financial Services - Amazon Web Services' (Amazon Web Services, Inc.) <<https://aws.amazon.com/financial-services/>> accessed 10 January 2023.

¹¹ 'Microsoft Cloud for Financial Services | Microsoft' <<https://www.microsoft.com/en-us/industry/financial-services/microsoft-cloud-for-financial-services>> accessed 10 January 2023.

¹² 'Financial Services' (Google Cloud) <<https://cloud.google.com/solutions/financial-services>> accessed 10 January 2023.

¹³ 'Industry CloudPath 2021: Executive Summary Report' (n 9).

¹⁴ *ibid.*

¹⁵ Barbieri (n 1).

¹⁶ See for a comprehensive analysis of the risks of the use of CSPs, Kuan Hon, Millard and Singh (n 5).

¹⁷ Anthony Bisong and Syed Shawon M. Rahman, 'An Overview Of The Security Concerns In Enterprise Cloud Computing' (2011) 3 International Journal of Network Security & Its Applications 30.

¹⁸ Daniele Catteddu, 'Cloud Computing: Benefits, Risks and Recommendations for Information Security' in Carlos Serrão, Vicente Aguilera Díaz and Fabio Cerullo (eds), *Web Application Security* (Springer 2010).

¹⁹ Hal S Scott, 'The E.U.'s Digital Operational Resilience Act: Cloud Services & Financial Companies' (Social Science Research Network 2021) SSRN Scholarly Paper 3904113 <<https://papers.ssrn.com/abstract=3904113>> accessed 13 May 2022.

²⁰ Kuan Hon, Millard and Singh (n 5).

²¹ Daniel Gozman, Tim Machaiah and Leslie Willcocks, 'Cloud Sourcing and Mitigating Concentration Risk in Financial Services', *Information Systems Outsourcing* (Springer International Publishing 2020).

services in Australia were affected by the 2016 AWS outage, leaving many customers unable to use their cards or ATMs.²² Another AWS outage hit GitHub, Adobe, Citrix, Salesforce, and Autodesk in 2017. Companies lost \$150 million as a result of a human error at Amazon, which also prevented updating its dashboard.²³ Despite the incident, AWS reported 99.99 % service and data availability.

Another risk of the increased use of cloud services by FIs is the concentration risk due to the limited number of CSPs. The concentration risk has systemic implications from the perspective of financial stability.²⁴ Few companies lead the market as it grows. AWS has maintained its position as an early leader in the market for cloud infrastructure. According to Synergy Research Group, it is estimated that Amazon's market share in the global cloud infrastructure market would be 34 % in the third quarter of 2022, still exceeding the combined market share of its two main competitors, Microsoft Azure and Google Cloud.²⁵

If a considerable number of FIs decide to enter into a contract with a CSP for critical services and said CSP encounters an incident that disrupts availability, thereby impacting the operational continuity of the involved banks, the ramifications could extend to the entire banking system. The cloud environment presents an amplified concentration risk due to the dominance held by a small set of prominent providers. Gozman and Machaiah offer a pertinent exemplification of concentration risk in the use of CSPs within the financial domain.²⁶ Temenos, a banking platform based on the cloud, is leveraged by FIs like Metrobank, Banco Capital, and Tandem Bank. In a theoretical scenario where Microsoft, a major CSP provider, encounters an availability setback, the potential reverberations across all downstream entities are substantial, significantly magnifying the existing financial stability vulnerabilities.²⁷

Considering these risks and benefits, the EU financial sector legal instruments impose responsibilities upon FIs to mitigate these risks while using CSPs. The risk of the use of CSPs is considered as operational risk before Digital Operational Resilience Act (DORA, 2022/2554),²⁸ which was adopted in December 2022 and will go into effect on January 17, 2025. Now, DORA shifts the regulatory focus from operational risk to systemic risk in the context of CSP usage. This transformation is in the form of establishing new oversight of critical ICT third-party providers, particularly for critical cloud service providers (CCSPs).²⁹ Thus, the interrelated research questions addressed in this paper are:

- How do EU financial sector-specific legal instruments transition from regulating operational risk to systemic risk in CSP usage?
- What implications does this regulatory transformation have on *ne bis in idem principle* under Article 50 of the Charter of Fundamental Rights of the European Union (CFREU), especially in light of overlapping supervision by various regulatory authorities?

To respond to these questions, this paper analyses how the regulation of CSPs used by FIs is being transformed in the EU financial sector-specific legal instruments by considering the new risks posed by the CSPs. In this paper, I argue that EU financial sector-specific legal instruments are transformed from the regulation of operational risk to the regulation of systemic risk to mitigate the risks of the use of CSPs to FIs, which is discussed in Section 2. This transformation brings new EU-level oversight for critical ICT third-party providers, in particular CCSPs. This oversight regime engenders a significant regulatory challenge characterized by the overlapping oversight of CCSPs within the EU, which is discussed in Section 3. This regulatory quandary arises primarily due to the concurrent exercise of oversight by distinct competent authorities responsible for overseeing cybersecurity, as stipulated in Network and Information Security Directive (NIS 2 Directive, 2022/2555), and personal data protection, as delineated by the General Data Protection Regulation (GDPR, 2016/679). The juxtaposition of these oversights impels an inquiry into the extent to which this overlapping oversight adheres to the foundational *ne bis in idem principle*, which posits that no one should be subject to double criminal proceedings for the same criminal offence.

To provide context for the paper, Section 2.1 examines the EU financial regulatory framework, which governs the use of CSPs by FIs based on operational risk before the adoption of DORA. In Section 2.2, I assess the shortcomings of the regulation of the use of cloud services as an operational risk by analysing the systemic risk aspect of the use of cloud service providers. In the same section, I do an overall analysis of DORA to show the transformation from operational risk to systemic risk. As a response to systemic risk, the new oversight framework for CCSPs is established, which is discussed comprehensively in Section 3. However, establishing a new oversight regime for CCSPs brings new challenges regarding the overlapping oversight of CCSPs that are already subject to oversight by different authorities. In this section, I investigate to what extent the new oversight regime overlaps with the oversights in other EU legal instruments in personal data protection and cybersecurity. After showing the overlapping oversight, I evaluate to what extent the overlapping oversight regime respects *ne bis in idem principle*. In addition, I give suggestions to improve the oversight mechanism to respect *ne bis in idem principle*. In the same section, I propose two different future policy options concerning overlapping oversight.

This article contributes to the legal literature in three key areas. Firstly, it undertakes an analysis of the conceptualisation of systemic risk concerning the challenges posed by CSPs. This examination provides valuable insights into understanding the specific risks associated with CSPs. Secondly, the article delves into an intricate exploration of the overlapping oversight framework situated at the juncture of three pivotal regulatory pillars: GDPR, NIS 2, and DORA. It raises questions about the appropriateness of this convergence of regulatory oversight, employing the *ne bis in idem principle* as a critical evaluative criterion. This evaluation casts a revealing spotlight on the intricate oversight landscape within the realms of cybersecurity and data protection, particularly in the context of the financial sector. Thirdly, the article contributes to the broader discourse surrounding the convergence of financial regulation and data governance³⁰ by discussing the overlapping oversight concerning cybersecurity in the context of the use of CCSPs.

²² *ibid.*

²³ *ibid.*

²⁴ See Section 2.2 for the further analysis, *ibid.*; Juan Carlos Crisanto and others, 'Big Tech Interdependencies – a Key Policy Blind Spot'; Kuan Hon, Millard and Singh (n 5); Maziar Peihani, 'Regulation of Cyber Risk in the Banking System: A Canadian Case Study' [2022] *Journal of Financial Regulation* fjac006; Financial Stability Board, 'Third-Party Dependencies in Cloud Services: Considerations on Financial Stability Implications' (9 December 2019) <<https://www.fsb.org/2019/12/third-party-dependencies-in-cloud-services-considerations-on-financial-stability-implications/>> accessed 10 January 2023.

²⁵ 'Infographic: Amazon, Microsoft & Google Dominate Cloud Market' (Statista Infographics) <<https://www.statista.com/chart/18819/worldwide-market-share-of-leading-cloud-infrastructure-service-providers/>> accessed 9 January 2023.

²⁶ Gozman, Machaiah and Willcocks (n 21)

²⁷ *Ibid.*

²⁸ Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (Text with EEA relevance)

²⁹ See the similar approach towards to oversight of the critical technology provider in the UK by the adoption of Financial Services and Markets Act 2023, see Travers Smith, 'Financial Services and Markets Act 2023: Building a Smarter Regulatory Framework in the UK?' (Travers Smith ⁵¹ <<https://www.traverssmith.com/knowledge/container/financial-services-and-markets-act-2023-building-a-smarter-regulatory-framework-in-the-uk/>> accessed 7 September 2023.

³⁰ Arner, Castellano and Selga (n 2).

2. The regulation of the use of CSPs as an operational risk in the EU financial legal instruments and its transformation to systemic risk in DORA

After a rogue trader collapsed Barings Bank, in 1995, “operational risk” became popular in banking and regulation.³¹ This event demonstrated the significance of internal controls and corporate governance in managing losses from fraud, human errors, technical failures, and other business process breakdowns. The biggest operational risks are internal control and governance failures. Operational risk also includes major IT system failures and disasters like fires. Regarding the supervisory role of financial regulators, the consensus was that regulatory supervisors should only promote “qualitative improvements” in operational risk management by raising awareness and sharing best practices.³²

Operational risk is defined in Basel II, considered a global standard rule for FIs as “the risk of losses resulting from inadequate or failed internal processes, people, systems, or external events” according to the Basel Committee on Banking Supervision (BCBS), the primary global standard-setter on financial regulation.

Basel II imposes two primary obligations regarding operational risk on banks. These obligations are the risk management strategies employed to address operational risk and the corresponding capital requirements necessary for mitigating such risks.³³ The latter refers to the minimum amount of capital that a bank is required to allocate for operational risks.³⁴ The former means that FIs should have processes and controls to mitigate operational risk. The management of operational risk is mainly based on principle-based corporate governance responsibilities, internal control mechanisms, and the supervision of these processes and controls by financial regulators. While there are adjustments concerning the calculation of capital requirements in subsequent versions of Basel II, namely Basel III and IV,³⁵ the approach to risk management is similar in Basel III and Basel IV. Regarding the latest update on the risk management of operational risk, the BCBS released “Principles for Operational Resilience”³⁶ in March 2021, building on its operational risk guidance. The document acknowledges that technology adoption and third-party technology services are among the main operational risks for banks, which will be further discussed in the following section. Other than this emphasis, the document does not offer a fresh perspective or a forward-thinking approach.³⁷

The consideration of the risks arising from the use of CSPs as an operational risk can be found in the EU financial law instruments. Callies and Baumgarten provide examples of legal instruments that cover the consideration of cybersecurity risk as operational risk, which includes the risks of using CSPs.³⁸ For instance, Art. 74 of the Capital

Requirements Directive (CRD IV) requires that FIs shall have “robust governance arrangements” and “adequate internal control mechanisms” to “identify, manage, monitor and report the risks.” As the risks included third-party risks, the use of CSPs falls within the scope of the requirement under Art. 74 of CRD IV.³⁹

2.1. Regulation of the use of cloud service providers as the operational risk through outsourcing in the EU financial legal instruments

FIs have to manage the risks arising from the use of cloud services as part of their operational risk management responsibilities. The operational risks caused by the use of CSPs by FIs are considered part of third-party risks since they come from third-party service providers. When the risk is related to the use of third parties by FIs, these risks fall within the outsourcing requirements of EU financial regulation.⁴⁰ Whether the use of cloud services by financial services falls within the definition of outsourcing is decisive to see whether the outsourcing requirements discussed later apply.

2.1.1. Definition of outsourcing and its applicability to the use of cloud services

While there is no unified definition of outsourcing within the financial sector, Laaper provides a comprehensive definition based on the evolution of outsourcing requirements. According to him, the definition is “the use of a third party for the performance of any aspect of the outsourcing firm’s material functions that would otherwise be undertaken by the entity itself.”⁴¹ There are three main elements to this definition: third party, own activities and material activities. The use of third-party service providers is required. Thus, internal delegation is not outsourcing. The third party may be a corporate group affiliate or an external entity.⁴² Outsourcing only includes tasks that would have been done by the entity itself otherwise. Thus, providing food and having insurance policies sent by mail are not examples of outsourcing within the FIs. FIs’ activities aren’t limited to their regulated activities. The practice of outsourcing is restricted to only those tasks that are significant for the financial firm, its customers, or the supervision that is provided by the regulatory authorities. The definition of a material activity includes regulated activities. When it comes to activities that aren’t regulated, the materiality of the service has to be evaluated on a case-by-case basis.

On the one hand, Hon, Millard and Singh comprehensively discuss whether the use of cloud services can be considered outsourcing.⁴³ They argue that cloud computing has some key characteristics that set it apart from traditional outsourcing: the difference between active agency and provision of passive resources, sequence of events, standardized shared

³¹ See for the details of the collapse of Barings Bank, ‘The Collapse of Barings Bank’ (*Ethics Unwrapped*) <<https://ethicsunwrapped.utexas.edu/case-study/collapse-barings-bank>> accessed 11 January 2023.

³² <https://www.bis.org/publ/bcb96.pdf> See for the latest version, ‘Principles for the Sound Management of Operational Risk’ updated in 2021 <<https://www.bis.org/publ/bcb95.htm>> accessed 11 January 2023.

³³ See for comprehensive analysis of capital requirements for operational risk, Peter Sands, Gordon Liao and Yueran Ma, ‘Rethinking Operational Risk Capital Requirements’ (2018) 4 *Journal of Financial Regulation* 1.

³⁴ As this article focuses on outsourcing as part of the risk management responsibilities, it does not delve into the details of the capital requirements for operational risk, for further information see, *ibid*; Peihani (n 24); Allen N Berger and others, ‘Operational Risk Is More Systemic than You Think: Evidence from U.S. Bank Holding Companies’ (2022) 143 *Journal of Banking & Finance* 106619.

³⁵ Sands, Liao and Ma (n 33).

³⁶ ‘Principles for the Sound Management of Operational Risk’ (n 32).

³⁷ Peihani (n 24).

³⁸ Christian Callies and Ansgar Baumgarten, ‘Cybersecurity in the EU the Example of the Financial Sector: A Legal Perspective’ (2020) 21 *German Law Journal* 1149.

³⁹ *ibid*; See also for different EU legal instruments applying to financial sector, Anton N Didenko, ‘Cybersecurity Regulation in the Financial Sector: Prospects of Legal Harmonization in the European Union and Beyond’ (2020) 25 *Uniform Law Review* 125.

⁴⁰ Peter Laaper, ‘The Cross-Sectoral Playing Field in Outsourcing’ in Veerle Colaert, Danny Busch and Thomas Incalza (eds), *European Financial Regulation : Levelling the Cross-Sectoral Playing Field* (1st edn, Hart Publishing 2019) <<http://www.bloomsburycollections.com/book/european-financial-regulation-leveling-the-cross-sectoral-playing-field/ch11-the-cross-sectoral-playing-field-in-outsourcing/>> accessed 28 January 2020.

⁴¹ *ibid*. This definition is based on the findings in P Laaper, *Uitbesteding in de financiële sector, in het bijzonder van vermogensbeheer door pensioenfondsen*, (Deventer, Wolters Kluwer, 2015), p 32–49

⁴² *ibid*.

⁴³ W Kuan Hon, Christopher Millard and Jatinder Singh, ‘Cloud Technologies and Services’ in Christopher Millard (ed), *Cloud Computing Law* (Oxford University Press 2021) <<https://doi.org/10.1093/oso/9780198716662.003.0001>> accessed 9 January 2023; W Kuan Hon and Christopher Millard, ‘Banking in the Cloud: Part 2 – Regulation of Cloud as “Outsourcing”’ (2018) 34 *Computer Law & Security Review* 337.

infrastructure, level of knowledge and degree of control.⁴⁴ I specifically focus on the difference between active agency and the provision of passive resources, and the degree of control. This is because they are more related to the definition of outsourcing in particular regarding the elements of “own activities” and “materiality.” Regarding the former one, CSPs may not act as agents who actively process data for customers, but they may passively store data that customers choose to store and otherwise process on the provider’s infrastructure.⁴⁵ For instance, in the model of IaaS, CSPs provide passive resources to FIs for their activities. In addition, it is challenging to consider this type of service provision as FIs’ activities and within the scope of “materiality.” Similarly, regarding the control level, private clouds offer the greatest degree of customization and control, particularly when hosted on a customer’s infrastructure and managed by the customer.

On the other hand, while I acknowledge that the concept of outsourcing is not a perfect fit for the use of CSPs, I argue that outsourcing is a familiar concept to FIs concerning the use of third parties in the financial sector. Thus, broadening the concept of outsourcing to third-party risk, including the use of CSPs in general might be a solution for operational risk management responsibilities. European Banking Authority (EBA) seems to take this type of approach. In its Guidelines (EBA Guidelines), EBA states that FIs consider that getting services, including IT services, from third parties creates risks, even if the arrangements are not outsourcing or involve non-critical or important functions. To manage all risks, institutions and payment institutions should assess the operational and reputational risks from those arrangements.⁴⁶ Similarly, the European Insurance and Occupational Pensions Authority (EIOPA) clarifies that in cases where the undertaking outsources operational functions or activities to service providers that are not CSPs but rely heavily on cloud infrastructures to deliver their services (for example, where the cloud service provider is part of a sub-outsourcing chain), the arrangement for such outsourcing is covered by these Guidelines.⁴⁷

In conclusion, there are indeed a variety of differences between the use of CSPs and the elements of the traditional outsourcing definition. As the outsourcing concept is related to third-party risk, it might be understandable to broaden this concept and apply the legal requirements of outsourcing to the use of cloud services considering the risks caused by the use of cloud services.

2.1.2. Outsourcing requirements in the EU financial legal instruments

In EU financial legal instruments, the regulatory framework for outsourcing varies according to the types of FIs.⁴⁸ For instance, for credit institutions, Art. 74 of the CRD IV is within the requirements of outsourcing, which is part of the governance arrangements that are referred to. For payment institutions and electronic money institutions, Art. 19 and Art. 20 of Directive 2015/2366/EU (PSD2) stipulate outsourcing requirements. Directive 2014/65/EU (MiFID II) includes explicit provisions for the outsourcing of investment services and activities. For insurance and reinsurance firms, Art. 49 of Directive 2009/138/EC (Solvency II) sets forth similar outsourcing requirements.

These regulatory requirements are detailed in the specific guidelines

adopted by the relevant EU supervisory authorities in different sub-sectors of the financial sector. EBA, which is responsible for the supervision of banks, payment and electronic money institutions, published EBA Guidelines in 2019 and integrated the EBA recommendation on outsourcing to CSPs,⁴⁹ published in December 2017. In 2020, the European Securities and Markets Authority (ESMA) and EIOPA adopted their specific guidelines on the use of CSPs.⁵⁰

Regarding the underlying principles of outsourcing requirements in the EU legal instruments and the Guidelines, I agree with Laaper on the argument that six principles underlie the outsourcing requirements in EU financial regulation: retention of responsibility, retention of control, retention of supervisory powers, proportionality, materiality, and freedom to outsource.⁵¹ I will give examples from the EBA Guidelines while describing these principles. First, the retention of responsibility means that FIs continue to be accountable and are mainly responsible for the risks arising from outsourced activities. As a reflection of this principle, EBA Guidelines state that outsourcing functions must not result in the delegation of management responsibilities. FIs continue to bear full responsibility and accountability for meeting all of their regulatory obligations.⁵²

Second, the retention of control means that the FIs that outsource their activities should be in control of the outsourced activities. Control can be exercised through contractual supervision arrangements. For example, the control by FIs can be exercised via the audit rights stipulated in the contract between FIs and CSPs.⁵³ Third, the retention of supervisory powers means that the supervisory authorities shall exercise their supervision capacity for the function that is outsourced. Otherwise, the supervisory authorities are not able to oversee the activities related to that function.⁵⁴ For instance, the exercise of supervisory authorities over outsourced activities can be carried out by granting the unrestricted right to inspect and audit the service provider for outsourced activities.⁵⁵ Fourth, proportionality ensures that governance arrangements, including outsourcing, are consistent with the institution’s risk profile, nature, and business model. If outsourcing a specific function poses less risk, its control and supervision should be adjusted accordingly. Fifth, the materiality principle, based on the proportionality principle,⁵⁶ ensures that not all outsourced functions are equally risky in terms of outsourcing requirements. In other words, outsourcing critical or important functions⁵⁷ necessitates stricter control and supervision. Sixth, the freedom to outsource means that no outsourcing requirement prohibits or requires any activity to be outsourced.⁵⁸ Outsourcing is made through contractual agreements between FIs and third-party service providers.

Regarding the specific requirements for the use of CSPs, the EBA

⁴⁹ ‘Recommendations on Outsourcing to Cloud Service Providers’ (European Banking Authority, 28 March 2018) <<https://www.eba.europa.eu/regulation-and-policy/internal-governance/recommendations-on-outsourcing-to-cloud-service-providers>> accessed 7 February 2023.

⁵⁰ Ramona Delcea, ‘Guidelines on Outsourcing to Cloud Service Providers’ (EIOPA - European Commission, 6 February 2020) <https://www.eiopa.europa.eu/document-library/guidelines/guidelines-outsourcing-cloud-service-providers_en> accessed 13 January 2023; ‘Guidelines On Outsourcing to Cloud Service Providers’ <<https://www.esma.europa.eu/document/guidelines-outsourcing-cloud-service-providers>> accessed 13 January 2023.

⁵¹ Laaper (n 40).

⁵² See para. 36 of the EBA Guidelines.

⁵³ See para. 47 of the EBA Guidelines and Guideline 11 of EIOPA Guidelines.

⁵⁴ See para. 44 of EBA Guidelines.

⁵⁵ EBA Guidelines para. 75(p) for the outsourcing activities, see para. 79(b).

⁵⁶ The proportionality principle will be further discussed.

⁵⁷ Para. 29 of EBA Guidelines provides different situations in which the outsourcing the critical or important function occurs.

⁵⁸ See for certain exceptions, Laaper (n 40).

⁴⁴ Kuan Hon, Millard and Singh (n 43).

⁴⁵ *ibid.*

⁴⁶ Para. 24 of the EBA Guidelines.

⁴⁷ EIOPA Guidelines, Guideline 1. https://www.eiopa.europa.eu/sites/default/files/publications/eiopa_guidelines/guidelines_on_outsourcing_to_cloud_service_providers_en.pdf

⁴⁸ See for the regulatory framework for the outsourcing, Laaper (n 40). and for the specific uses of CSPs, Hon and Millard (n 43). For comparative analysis of the different regulatory frameworks in the US, UK and EU, see Daniel Gozman and Leslie Willcocks, ‘The Emerging Cloud Dilemma: Balancing Innovation with Cross-Border Privacy and Outsourcing Regulations’ (2019) 97 Journal of Business Research 235.

Guidelines, as an example of outsourcing requirements,⁵⁹ foresee three main areas: the governance framework, the outsourcing process (pre-outsourcing, during outsourcing, and exit from outsourcing), and exit strategies. First, the FIs shall have a governance framework that should be designed to comply with the operational risk management requirements.⁶⁰ This governance framework aims to concretize the principles of retention of control and retention of responsibility for outsourced activities. As an example of the retention of responsibility and control principle, the management body of FIs shall approve and ensure the implementation of the outsourcing policy.⁶¹ In addition, the outsourcing activities shall be documented and covered by the internal audit function of FIs. For the outsourcing process, firstly, as a consequence of the governance framework, FIs shall do a pre-outsourcing analysis by assessing whether outsourcing arrangements concern a critical or important function, the supervisory conditions for outsourcing and due diligence for the choice of the service provider for the specific function. Second, the contractual arrangements between FIs and service providers (such as CSPs) are ways of mitigating the risks arising from the use of third parties with respect to critical or important functions as well as retaining control and supervision over third-party activities.⁶² For instance, regarding the security risks (availability, confidentiality, and integrity), the EBA Guidelines require the insertion of a provision of the agreed service levels (for availability) as well as the security of data. For retention of control and supervision, the contract shall cover access, information, and audit rights for the financial institutions as well as the relevant financial competent authority. In that way, FIs and competent authorities shall retain control and supervision over the outsourced functions. On the one hand, these contractual provisions required by the EBA Guidelines pose a challenge for CSPs, who use standardized contracts⁶³ to provide their services. On the other hand, FIs used these requirements against the CSPs as leverage to negotiate the outsourcing contracts.⁶⁴ For instance, AWS published a specific blog on its services and EBA Guidelines and provided the EBA Financial Services Addendum as a result of these requirements.⁶⁵

Regarding the third requirement, FIs should develop an exit strategy to ensure that the continuation of their services will not be hampered in the event of any operational failure by the CSPs. Therefore, this exit strategy should take into account at least the possibility of termination of outsourcing arrangements, failure of the service provider, deterioration of the quality of the function, as well as material risks arising from the relationship between CSPs and FIs.

2.1.3. Overall assessment of consideration of the use of CSPs as operational risk

There are indeed differences between traditional outsourcing and the use of cloud services, such as the distinction between active agency and

passive resource provision. Nevertheless, it appears that EU financial regulators have extended the concept of outsourcing to include the use of cloud services, thereby governing the risks associated with FIs use of CSPs. Within their operational risk management responsibilities, FIs manage these risks through a focus on both their internal governance and the contractual governance associated with the use of CSPs. While these governance mechanisms will undoubtedly enhance the maturity and preparedness of specific FIs for the risks, it remains questionable to what extent these requirements respond to the concerns of concentration risk within the CSPs and systemic risks related to the financial stability implications of using CSPs, which are discussed in the following section.

2.2. The shortcoming of the regulation of the use of cloud services as operational risk and transformation of operational risk to systemic risk in DORA

There is very little consideration given to systemic issues, such as concentration risk or the negative impact that an operational disruption or the failure of CSPs would have on the entire financial system. This is conceptualised as a systemic risk⁶⁶ in the legal instruments that are before DORA. The question is to what extent the requirements within outsourcing instruments before DORA address the systemic implications of the use of CSPs. I argue that the requirements before DORA are not appropriate to address these implications. To substantiate my argument, I examine the systemic risk concept to elucidate why the utilization of CSPs can cause a systemic risk.

2.2.1. Cyber risk as a systemic risk to financial stability and concentrated cloud service market

While operational risk encompasses the risks associated with the utilisation of CSPs in the context of outsourcing requirements, cyber risk⁶⁷ stands out as a distinct category of risk, differing significantly from conventional risk sources such as credit, market, liquidity, or operational risk. Within the context of this framework, the concept of cyber risk can be understood as a component of operational risk, although it possesses distinct characteristics that set it apart. A notable differentiation exists in terms of the rate of dissemination. Cyber incidents can manifest and spread rapidly across systems, surpassing the velocity observed in other types of risk. For example, during the 2017 NotPetya incident, Ukrainian banks' systems were compromised almost instantaneously, highlighting the rapidity of such occurrences.⁶⁸ This was attributed to the interconnectivity of their automated information systems. Moreover, the magnitude of dissemination distinguishes cyber risk as a significant cyber incident that can result in more extensive repercussions than numerous other disruptions, surpassing geographical boundaries. Furthermore, the interconnectedness of information systems within the financial industry enables the extensive proliferation of cyber incidents across various sectors and geographical boundaries, thereby affecting entities that may not have been the primary targets. Another illustrative example is the incident of the Mastercard outage in 2018, which resulted in the disruption of credit card transactions in multiple regions and industries due to similar features of cyber risk.⁶⁹

Considering the aforementioned factors, the cyber risks arising out of

⁵⁹ For convergence and divergences with respect to the different Guidelines in the EU, Scott (n 19).

⁶⁰ Title III of the EBA Guidelines: Governance Framework.

⁶¹ See Section 7 of EBA Guidelines within Title III.

⁶² W Kuan Hon and Christopher Millard, 'Banking in the Cloud: Part 1 – Banks' Use of Cloud Services' (2018) 34 Computer Law & Security Review 4; W Kuan Hon and others, 'Negotiated Contracts for Cloud Services', *Cloud Computing Law* (2nd edn, Oxford University Press 2021) <<https://oxford.universitypressscholarship.com/10.1093/oso/9780198716662.001.0001/oso-9780198716662-chapter-4>> accessed 26 July 2022.

⁶³ Johan David Michels, Christopher Millard and Felicity Turton, 'Standard Contracts for Cloud Services' in Christopher Millard (ed), *Cloud Computing Law* (Oxford University Press 2021) <<https://doi.org/10.1093/oso/9780198716662.003.0003>> accessed 6 January 2023.

⁶⁴ Kuan Hon and others (n 62).

⁶⁵ 'AWS and the European Banking Authority Guidelines on Outsourcing | AWS Security Blog' (9 September 2019) <<https://aws.amazon.com/blogs/security/aws-european-banking-authority-guidelines-on-outsourcing/>> accessed 15 January 2023.

⁶⁶ Peihani (n 24); Gozman, Machaiah and Willcocks (n 21); Gozman and Willcocks (n 48).

⁶⁷ See the definition of cyber risk, Peihani (n 24).

⁶⁸ Andy Greenberg, 'The Untold Story of NotPetya, the Most Devastating Cyberattack in History' *Wired* <<https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>> accessed 7 September 2023.

⁶⁹ 'Global Mastercard Payment Outages Lead To Consumer Complaints' (13 July 2018) <<https://www.pymnts.com/mastercard/2018/outage-declined-credit-card-payments-europe/>> accessed 7 September 2023.

the use of CSPs can be considered a systemic risk. This is defined as the risk that an economic shock, such as market or institutional failure, triggers (through a panic or otherwise) a sequence of events leading to the failure of a chain of markets or institutions, a series of significant financial institution losses, or an increase in the cost of capital or decrease in its availability, often accompanied by substantial financial-market price volatility.⁷⁰ While the systemic risk concept in the financial system is traditionally associated with financial risks such as credit and liquidity risks, cyber risk has started to be considered as having systemic implications for the financial system. For instance, a cyber-attack causes disruptions to the capabilities of financial services, particularly payment systems, all over the world.⁷¹ In a 2020 report on systemic cyber risk,⁷² the European Systemic Risk Board (ESRB) reaffirmed how the existing high level of interconnectedness across financial entities, financial markets, and financial market infrastructures, and particularly the interdependencies of their ICT systems, may potentially constitute a systemic vulnerability. This is because cyber incidents could quickly spread from many of the approximately 22,000 Union financial entities to other entities.⁷³ They also enable the spread of vulnerabilities across financial transmission channels, which can cause liquidity runs and a loss of trust in financial markets, threatening the stability of the Union's financial system. If a systemically important financial is attacked or if multiple non-critical entities are linked, cyberattacks can cause systemic risk.⁷⁴ Similarly, cyberattacks on non-systemic entities only affect the firms affected, but interlinkages between entities can cause cascading effects that increase the risk of systemic threats when critical infrastructures are affected. The initial shock could be amplified by operational or financial contagion, or by a loss of confidence in the financial system. If the amplification mechanism is activated, the initial shock is likely to be transmitted through the financial system, potentially entangling financial institutions that were unaffected by the initial cyber incident.⁷⁵

Concerning the systemic risk implications of the use of CSPs, the interdependencies of FIs on the limited number of CSPs can be another factor in increasing systemic risk. For instance, if an excessive number of FIs choose to use the same CSP for critical or important services, and if that provider suffers an incident like an availability outage that disrupts the business continuity of the FIs involved, then the entire financial system may be negatively impacted. Similarly, according to a 2020 Bank of England survey, over 70 % of banks and 80 % of insurers use two CSPs for IaaS services.⁷⁶ This concentration emphasizes the financial sector's reliance on the CSPs. Failure of even one of the CSPs, or failure of a service, could eventually result in a significant event in financial services, with negative consequences for markets, consumers, and financial stability. Similarly, according to the policy paper published by the International Monetary Fund (IMF), the risks arising from the use of CSPs can be considered systemic. These include the centralization of risk, the provision of systemically important activities such as cloud services, and the interconnectedness of these limited number of service providers with

financial players.⁷⁷

The Cambridge Centre for Risk Studies presents a scenario wherein a hypothetical cyber event evolves into a significant economic crisis comparable to the 2007–08 global financial crisis.⁷⁸ This situation involves Sybil Corporation, an imagined technologically crucial enterprise, facing an incident caused by an insider that impacts its flagship database product. A dissatisfied employee introduces a floating-point error computation, leading to the random appearance of errors on numerous servers utilizing Sybil's database. Given Sybil Corporation's global ICT influence, this error spreads, compromising data integrity across various platforms, industries, and sectors. The revelation of the cyber incident triggers panic due to uncertainty regarding data accuracy, integrity, and the extent of affected companies.

Similarly, the report published by the ESRB presents a scenario wherein the use of CSPs contributes to systemic risk, precipitating an economic crisis.⁷⁹ In this scenario, a major bank, Bank Y, faces a cyberattack orchestrated by threat actors who exploit vulnerabilities in its IT systems and those of its outsourced contractors. These attackers compromise data integrity, leading to wiped account balances and disrupted payment processes. Initially isolated to Bank Y, the incident triggers a chain reaction of consequences. Manual workarounds prove inadequate, prompting regulatory involvement and a decline in public confidence. Bank Y's efforts to restore services falter due to compromised recovery plans. Then, this operational disruption escalates into financial distress. Institutional customers experience payment failures, intensifying the crisis. An exacerbated scenario involves the exploitation of social media to erode confidence in the financial system. Ultimately, the loss of data becomes systemic, impacting not just Bank Y but its counterparts and the country's payment systems. Authorities grapple with coordination challenges, and customers attempt to shift funds, worsening data integrity and confidence issues, which lead to the systemic impact. This scenario underscores CSPs' potential to magnify systemic risk, triggering a severe economic crisis.

In conclusion, the intertwining of cyber risk and operational risk, especially about the use of CSPs, has highlighted the potential for these risks to escalate into systemic risks that can trigger economic crises. While operational risk encompasses the challenges of utilizing CSPs within the framework of outsourcing, the unique characteristics of cyber risk set it apart from conventional risk sources like credit, market, liquidity, and operational risk. The emergence of systemic risk in the financial system due to cyber risk has garnered attention from authorities, with organizations such as ESRB emphasizing the vulnerabilities stemming from interconnectivity and the potential for cascading effects. Furthermore, the concentration of FIs on a limited number of CSPs introduces an additional aspect to the systemic risk, as highlighted by the Cambridge Centre for Risk Studies' scenario and the illustration of Bank Y's crisis. This concentration amplifies the financial sector's dependence on these service providers, raising concerns about the potential ripple effects of CSP failures.

2.2.2. Uncovering the blind spot: Systemic risk and the outsourcing requirements in the EU financial legal instruments

After discussing the use of CSPs as a systemic risk to financial stability, I argue that the legal requirements before DORA regarding

⁷⁰ See the integrated definition of systemic risk and the justification for its regulation, Steven Schwarcz, 'Systemic Risk' (2008) 97 Georgetown Law Journal 193.

⁷¹ Paul Mee and Til Schuermann, 'How a Cyber Attack Could Cause the Next Financial Crisis' [2018] *Harvard Business Review* <<https://hbr.org/2018/09/how-a-cyber-attack-could-cause-the-next-financial-crisis>> accessed 16 January 2023.

⁷² European Systemic Risk Board., *Systemic Cyber Risk*. (Publications Office 2020) <<https://data.europa.eu/doi/10.2849/566567>> accessed 13 May 2022.

⁷³ See Recital 3 of DORA.

⁷⁴ John Fell and others, 'Towards a Framework for Assessing Systemic Cyber Risk' <https://www.ecb.europa.eu/pub/financial-stability/fsr/special/html/ecb.fsrart202211_03~9a8452e67a.en.html> accessed 16 January 2023.

⁷⁵ European Systemic Risk Board. (n 72).

⁷⁶ 'How Reliant Are Banks and Insurers on Cloud Outsourcing?' <<https://www.bankofengland.co.uk/bank-overground/2020/how-reliant-are-banks-and-insurers-on-cloud-outsourcing>> accessed 16 January 2023.

⁷⁷ Parma Bains Wilson Nobuyasu Sugimoto, Christopher, 'BigTech in Financial Services: Regulatory Approaches and Architecture' (IMF) <<https://www.imf.org/en/Publications/fintech-notes/Issues/2022/01/22/BigTech-in-Financial-Services-498089>> accessed 16 January 2023. See for another policy paper, Crisanto and others (n 24).

⁷⁸ 'Sybil Logic Bomb Cyber Catastrophe Stress Test Scenario' (Cambridge Judge Business School) <<https://www.jbs.cam.ac.uk/faculty-research/centres/risk/publications/technology-and-space/sybil-logic-bomb-cyber-catastrophe-stress-test-scenario/>> accessed 7 September 2023.

⁷⁹ European Systemic Risk Board. (n 72).

operational risk and outsourcing do not explicitly address the systemic risk arising from the use of CSPs. However, the EBA Guidelines reaffirm the systemic implications of the concentration risk that arises from the use of cloud services.⁸⁰ The Guidelines mention consideration of concentration risk while providing guidelines to FIs as well as the national competent authorities. They also refer to the concentration risk in the requirements of outsourcing in different aspects of outsourcing. For instance, FIs should consider the concentration risk while determining their outsourcing activities to a limited number of service providers in their risk assessment⁸¹ or during the oversight of the outsourced activity.⁸² Regarding the guidelines given to the national competent authorities, the Guidelines stipulate that the supervision over outsourcing activities might cause a concentration risk, both for individual institutions and for the industry as a whole, since large CSPs can become a single point of failure when many institutions rely on them.⁸³ Therefore, the Guidelines require that national competent authorities, where concentration risks are identified, monitor their development and evaluate both their potential impact on other institutions and payment institutions as well as the financial market's stability.⁸⁴

These Guidelines indeed refer to the concentration risk and provide certain guidance on how to mitigate the systemic implications of the use of CSPs. However, the Guidelines might not be considered sufficient since they provide discretion to individual FIs and national competent authorities to determine the concentration risk and its mitigation model. Despite affording FIs and national competent authorities a degree of discretion, these discretionary powers may lack efficacy for several compelling reasons. Foremost among these is the inherent challenge in assessing concentration risk, coupled with its attendant perils, which can solely be comprehensively gauged at the macroeconomic level of a systemic impact analysis. Thus, FIs face a nearly insurmountable hurdle in accurately evaluating the concentration risk induced by their engagement with CSPs. Secondly, the Guidelines posit that FIs and national competent authorities can effectively supervise CSPs by relying on contractual safeguards that mandate the oversight role of financial institutions and their respective competent authorities. Nevertheless, this assumption finds itself under scrutiny in light of findings from a survey for the ESRB Report, rendering it a questionable premise.⁸⁵ The outcomes of the ESRB-conducted survey underline a prominent concern within the realm of cybersecurity vulnerabilities encountered by FIs and competent authorities in the financial sector. Notably, the most pressing issue pertains to inadequate oversight of third-party suppliers and their associated supply chains. Consequently, the existing requisites concerning outsourcing fail to adequately encompass the broader systemic ramifications stemming from the utilization of CSPs.

2.2.3. DORA as a response to systemic risk in micro-prudential regulation

To address the systemic implications of cybersecurity⁸⁶ in the financial sector as well as harmonisation in the sector,⁸⁷ on September 24, 2020, the European Commission presented the proposed DORA.⁸⁸ It was part of a larger digital finance package aimed at developing a

European approach that promotes technological development while also ensuring financial stability and consumer protection.⁸⁹ DORA was published in the Official Journal of the European Union on 27 December 2022. DORA entered into force twenty days after its publication in the Official Journal of the European Union. It will take effect on January 17, 2025.

DORA, according to Art. 2, applies to financial entities, which were referred as FIs in this paper. DORA aims to harmonise the requirements regarding the cybersecurity risks to different entities within the financial sector. Thus, it applies not only to credit institutions, and payment institutions but also to different types of entities involved in the financial sector, including investment firms, electronic money institutions, insurance and reinsurance entities, as well as ICT third-party service providers.

DORA covers four main pillars in its subject matter according to Art. 1 of DORA. The first is the cybersecurity requirements (ICT risk management, reporting of ICT-related incidents and notifications, digital operational resilience testing, and information and intelligence sharing related to financial entities). The second is related to the requirements related to the contractual agreements between ICT third-party service providers and financial entities. The third is regarding the rules on the oversight framework for critical ICT third-party service providers when providing services to FIs. Lastly, the fourth is pertinent to the rules of cooperation between competent authorities.

DORA is a micro-prudential-focused regulation. It aims to impose different cybersecurity requirements on individual financial entities to increase their resilience to cybersecurity risks in its entirety. In other words, its focus is not to prevent all systemic risks implications of cybersecurity risks.⁹⁰ However, focusing on the individual resilience of financial entities will have a positive impact on the financial sector's resilience in three aspects. The first aspect is that financial entities are subject to detailed risk management responsibilities. When financial entities take these measures, it increases their preparedness. The second aspect is to improve coordination to deal with the systemic consequences of cybersecurity risks and incidents. Financial authorities must improve their readiness for a systemic cyber crisis by improving communication and coordination capabilities at the EU level to reduce the risk of coordination failure.⁹¹ The coordination between financial entities via information sharing arrangements,⁹² between financial entities and relevant competent authorities via harmonised incident notification requirements⁹³ and between different competent authorities.⁹⁴ The third component regulates third-party risk and establishes an oversight framework for critical ICT third-party providers, which will be discussed further in Section 3.

When financial entities meet these requirements, it increases the resilience of a wide range of financial entities involved in the financial sector. Because DORA imposes standardized responsibilities on all of these entities, it has the potential to reduce systemic cybersecurity risks by increasing the resilience of financial entities on an individual level.⁹⁵ However, it does not mean that the systemic risk is fully mitigated with micro-prudential regulation. Macro-prudential requirements will be designed to function as a supplementary mechanism to micro-prudential regulation, establishing a cohesive and all-encompassing structure that

⁸⁰ EBA Guidelines refer to the concentration and systemic risk, see para. 45.

⁸¹ EBA Guidelines para. 25. and para. 66.

⁸² Ibid., para. 103

⁸³ Ibid., para. 46.

⁸⁴ Ibid., para. 117.

⁸⁵ European Systemic Risk Board. (n 72).

⁸⁶ Recital 3, 30 and 31 of DORA.

⁸⁷ See Recital 8 and 9 of DORA.

⁸⁸ Proposal for a REGULATION OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014 and (EU) No 909/2014 available at <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52020PC0595>

⁸⁹ 'Digital Finance Package' <https://finance.ec.europa.eu/publications/digital-finance-package_en> accessed 17 January 2023.

⁹⁰ European Systemic Risk Board., *Mitigating Systemic Cyber Risk: January 2022*. (Publications Office 2022) <<https://data.europa.eu/doi/10.2849/99500>> accessed 8 January 2023. This report outlines how the systemic risk through macroprudential regulation can be mitigated.

⁹¹ *ibid.*

⁹² Art. 45 of DORA.

⁹³ Art. 17- 23 of DORA.

⁹⁴ See Art. 47, 48 and Art. 49.

⁹⁵ See Art. 5-16 of DORA.

effectively tackles both the risks at the individual institution level and the systemic vulnerabilities that have the potential to propagate throughout the financial domain.⁹⁶

The use of CSPs by FIs is subject to requirements addressing ICT third-party risk. DORA has established a unified and clear definition of this risk. Per Art. 3(14), ICT third-party risk is defined as the risk faced by a financial entity due to its use of ICT services provided by third-party service providers. The use of CSPs by FIs is subject to requirements related to ICT third-party risk. DORA opted for a unified and clear definition of ICT third-party risk. According to Art. 3(14), ICT third-party risk is a risk that a financial entity may face as a result of its use of ICT services provided by ICT third-party service providers. The definition of “the ICT third-party service providers” is further clarified in Art. 3(15). According to this article, it refers to an organization that provides digital and data services, such as cloud computing services, software, data analytics services, and data centres.

Using the definition of the ICT third-party risk requirements rather than outsourcing requirements can be considered definitional clarity. As discussed in Section 2.1.1, traditional outsourcing and the use of cloud services are not identical. Because of these differences, legal scholars question whether the outsourcing requirements apply to all uses of cloud services.⁹⁷ Using the definition of ICT third-party risk, DORA clarified that regardless of the qualification of ICT services as outsourcing, FIs must comply with these requirements as long as there is a risk arising from the use of ICT services for FIs.

Despite the definitional shift from outsourcing to ICT third-party risk, the six outsourcing principles discussed in Section 2.1.2, (retention of responsibility, retention of control, retention of supervisory powers, proportionality, materiality, and freedom to outsource) remain similar as part of the ICT third-party risk requirements in DORA. For example, regarding the retention of responsibility, Art. 28(1) of DORA states that financial entities remain fully responsible for complying with the requirements of DORA and other financial law instruments. Regarding the retention of control, Art. 28(6) of DORA stipulates that the access, inspection, and audit of ICT third-party providers should be ensured. Regarding the proportionality principle, Art. 28(1)(b) of DORA refers to the principle of proportionality while managing the ICT third-party risks. Last but not least, the principle of materiality is still applicable as Art. 28(3) of DORA refers to the important or critical functions of financial entities and how third-party risk is specifically mitigated in those situations. Similarly, the mandatory key contractual provisions that shall be incorporated into the contracts between the CSPs and financial entities vary depending on the criticality of the function.⁹⁸

Similar to the specific requirements concerning the use of CSPs in the EBA Guidelines, DORA foresees three main requirements on the governance framework, the contractual process (pre-contractual, during, and after the contractual process), and exit strategies. For the requirements of governance of ICT third-party risk, similar to the EBA Guidelines, financial entities shall integrate this risk management framework into the general ICT risk management framework.⁹⁹ The requirements related to the contractual process are also similar to the EBA Guidelines. As an example of requirements related to the contractual process, DORA specifies key contractual provisions that the contracts between financial entities and ICT third-party providers should contain. These provisions include cybersecurity requirements, “the locations, namely the regions or countries, where the contracted or subcontracted functions and ICT services are to be provided” and cooperation with competent financial authorities.¹⁰⁰ Similar to the EBA Guidelines, FIs shall have exit

strategies that do not prejudice the continuity of their service in the case that they terminate their contractual relationship with the ICT third-party provider.

DORA, like the EBA Guidelines, requires FIs to conduct a preliminary assessment of ICT concentration risk at the entity level. The requirement is one of the tools that aims to lower concentration risk, particularly when using cloud services. Financial entities must conduct a risk assessment, which includes determining whether the ICT third-party service provider is easily substitutable or whether multiple arrangements with the same ICT third-party service provider are in place. Art. 29(1) of DORA specifies that the preliminary concentration assessment requirement is limited to the use of ICT services that support critical or important functions.

3. Navigating overlapping oversight regime for critical cloud service providers: Respecting the *ne bis in idem* principle in DORA, the NIS 2 Directive and GDPR

As discussed in Section 2.2.1, previously regarded as an operational risk, the use of CSPs is now widely recognised as a systemic risk in the financial sector. DORA, as mentioned in Section 2.2.3, marks a significant shift in the perception and management of cyber risk in the evolving landscape of financial sector regulation in contrast to previous requirements regarding outsourcing as explained in Section 2.2.2. This shift in perception is critical because it underpins the ESRB’s survey findings, which highlight a significant vulnerability: inadequate oversight of third-party suppliers. As a novelty, Section II of Chapter V of DORA responds to systemic risk by introducing a novel oversight framework aimed specifically at critical ICT third-party service providers, including CCSPs, which is at the centre of this paper.

At the EU level, this framework represents a strategic shift away from traditional operational risk management and towards a more systemic risk approach. It is not just about complying with requirements but also about recognising and actively managing the systemic implications of ICT providers’ operations and potential service disruptions. Thus, DORA aims to mitigate systemic risks by ensuring direct and robust supervision of these third-party interactions with FIs. This approach goes beyond simple compliance, encompassing a thorough examination of how disruptions in third-party services might affect the financial sector. DORA’s overarching goal is to foster a more resilient digital operational environment, by not only identifying but also proactively managing risks to ensure the financial sector’s stability in an increasingly digital and interconnected global economy.

This section argues that, while direct supervision of the CCSPs is critical to mitigating systemic risk to the financial sector, it is unclear to what extent the new oversight framework can be implemented in a co-ordinated manner given other overlapping oversight frameworks that aim to oversee CCSPs under the GDPR and the NIS 2 Directive. For this purpose, this Section, first critically examines the criteria utilised in the identification of ICT service providers, as well as the oversight structure and competencies outlined in DORA. The objective is to show that the oversight framework is a systemic risk-oriented tool. Second, it evaluates the degree of overlapping supervisory regime between DORA and the GDPR as well as the NIS 2 Directive. The aim is to see whether the new oversight framework respects the *ne bis in idem* principle that is stipulated under Article 50 of the CFREU in Section 3.2.2. The evaluation of the intersecting regulatory supervision between DORA and the NIS 2 Directive is conducted in Section 3.2.3, while the examination of the overlapping regulatory supervision between DORA and the GDPR is undertaken in Section 3.2.4. In Section 3.2.5, I provide possible future policy directions about the overlapping oversight regime.

3.1. Oversight of critical ICT service providers as a systemic risk-oriented tool under DORA

The oversight framework is to alleviate the systemic risks arising

⁹⁶ European Systemic Risk Board. (n 90).

⁹⁷ See Section 2.1.1.

⁹⁸ See Art. 30 of DORA.

⁹⁹ Art. 28 of DORA.

¹⁰⁰ Art. 30 of DORA.

from the engagement of ICT service providers, encompassing the utilization of cloud services. This intention is distinctly manifested in the criteria set forth for the identification of critical third-party ICT service providers, which notably align with the overarching apprehensions about systemic risk. According to Art. 31 of DORA, the European Supervisory Authorities (ESAs) through a Joint Committee shall designate an ICT third-party service provider as a critical ICT third-party service provider according to four main criteria. The first one is the systemic impact on the stability, continuity or quality of the provision of financial services in the event of an operational failure of the ICT third-party service provider. The second one is the systemic character or importance of financial entities that rely on the relevant ICT third-party service provider. The third one is the reliance of financial entities on these service providers for critical or important function. The fourth one is the degree of substitutability of these service providers.¹⁰¹

The criteria outlined in Article 31 of DORA are strategically focused on addressing concerns related to systemic risk when identifying critical third-party ICT service providers. The criteria encompass the evaluation of the potential systemic consequences on the stability, continuity, or quality of financial services in the event of an operational failure of ICT service provider. Equally important is the assessment of the systemic importance of financial entities that rely on the aforementioned provider, the level of dependence of these entities on the provider for critical or important operations, and the extent to which these services can be replaced. The oversight framework examines not only the operational integrity of individual service providers but also evaluates their integration and indispensability within the financial ecosystem. This approach acknowledges and aims to mitigate the potential repercussions that any disruption in their services may have on the wider financial system. The aforementioned approach highlights the transition in regulatory emphasis from the resilience of individual FIs to the broader systemic consequences arising from the interconnected nature of the digital financial environment.

The oversight forum will be established as a sub-committee of the Joint Committee, which is a forum for the EBA, EIOPA, and ESMA, also known as the ESAs.¹⁰² The ESAs will appoint a Lead Overseer among themselves for each critical ICT service provider according to Art. 31(1) (b) of DORA.

The newly established Lead Overseer has two main tasks according to Art. 34 of DORA. First, the assessment of critical ICT third-party providers to determine whether these service providers have appropriate processes and policies to ensure that the cybersecurity risk to the financial entities to which they provide service is mitigated. This assessment includes data security requirements including confidentiality, integrity and availability of data, physical security, risk management processes, governance arrangements, testing of their ICT system as well as ICT audits and their compliance with international standards.¹⁰³ Second, after the assessment, the lead overseer establishes a clear, detailed and reasoned individual annual oversight for each critical ICT service provider. To fulfil these tasks, the lead overseer has the powers to

request all relevant information,¹⁰⁴ conduct an investigation,¹⁰⁵ perform physical onsite inspections,¹⁰⁶ and issue recommendations.¹⁰⁷ Issuing recommendations include refraining critical ICT service providers from contracting with other sub-service providers in the case this type of subcontracting presents a clear and serious risk to the financial stability. If the critical ICT third-party provider does not comply with these recommendations, the lead overseer shall impose periodic penalty payments to compel the critical ICT service providers to comply with these recommendations. These periodic penalty payments shall be imposed daily up to 1 % of the average daily worldwide turnover by considering the gravity and duration of non-compliance; the intentional or negligent nature of the incompliance as well as the level of cooperation of critical ICT third-party service providers.¹⁰⁸ In addition, the Lead Overseer shall disclose the imposition of periodic penalties to the public¹⁰⁹ to compel the critical ICT provider to comply with these recommendations.

3.2. Unravelling the overlapping oversight tangle under DORA

The novel oversight framework implemented by DORA for CCSPs introduces overlapping oversight for CCSPs. The reason for this is that the CCSPs are already under the scrutiny of supervisory authorities (SAs) under the GDPR and of competent authorities under the NIS 2 Directive. The presence of these distinct oversight requires a thorough investigation into the extent to which their overlapping oversight authority is consistent with the fundamental principle of *ne bis in idem*. The aforementioned principle, which stipulates that an individual should not be subjected to multiple legal proceedings for a single transgression, necessitates a thorough evaluation of the regulatory framework in this particular context.

3.2.1. Juggling overlapping oversight for the CCSPs: Navigating the intersection of DORA with the NIS 2 Directive and GDPR

Given the importance of CCSPs in the digital economy, the CCSPs are already subject to cybersecurity responsibilities and oversight by competent authorities at the EU level, thanks to increased oversight in the NIS 2 Directive.¹¹⁰ In the NIS 2 Directive, the CCSPs are subject to full-fledged supervision by the competent authorities as they are considered digital infrastructure in Annex I (Sector of High Criticality) of the NIS 2 Directive. These authorities are equipped with on-site inspections, regular and targeted security audits, security scans, requests for information, and requests to access data and documents.¹¹¹ In addition, they have the power to issue warnings, adopt binding instructions, designate a monitoring officer and impose administrative

¹⁰¹ These criteria will be further specified by the delegated action adopted by the EU Commission according to Art. 31 of DORA.

¹⁰² See Art. 32(4) of DORA for the structure of the oversight forum, and compare with Art. 29(3) of the proposed DORA. In the final version of DORA, the more comprehensive and inclusive structure is established.

¹⁰³ Art. 33(3) of DORA.

¹⁰⁴ Art. 37 of DORA.

¹⁰⁵ Art. 38 of DORA.

¹⁰⁶ Art. 39 of DORA.

¹⁰⁷ See Art. 35(d) for the more specific types of recommendations.

¹⁰⁸ These criteria for penalty payments are inserted during the negotiations, see Art. 35(8) of DORA and compare with Art. 31(6) of the proposed DORA.

¹⁰⁹ Art. 35(10) of DORA.

¹¹⁰ See for further analysis of the NIS 2 Directive, Eyup Kun, 'Strengthening the Supervision and Enforcement in the EU Cybersecurity Law: Are All Organisational Measures Created Equally?' (Social Science Research Network 2021) SSRN Scholarly Paper ID 3933680 <<https://papers.ssrn.com/abstract=3933680>> accessed 18 February 2022.

¹¹¹ Art. 32(2) of the NIS 2 Directive.

finances in the case of non-compliance.¹¹²

It could be argued that DORA is *lex specialis* to the NIS 2 Directive. It means that more specific rules prevail over the general rules in this context. Thus, DORA would apply instead of the NIS 2 Directive since it includes more specific rules. As a result, there is no overlapping oversight for CCSPs. Nevertheless, upon closer examination, this argument appears to lack sufficient validity within DORA. For sure, Article 1(2) of DORA states that DORA is a sector-specific Regulation in relation to the NIS 2 Directive. This provision, on the other hand, clearly states that it is a sector-specific Regulation for financial entities that are considered important and essential entities under the national law that transposes the NIS 2 Directive. Recital 16 of DORA reinforces the scope of DORA's *lex specialis* by referring to only more stringent ICT risk management and ICT-related incident reporting requirements for financial entities in DORA. As a result, the novel oversight regime for CCSPs is not covered by DORA's *lex specialis* provisions. Thus, there is an overlapping oversight for CCSPs.

The oversight framework for the CCSPs also overlaps with the oversight mechanism in the GDPR.¹¹³ The overlapping oversight might occur because CCSPs can be considered a processor or controller depending on their role in the processing of personal data within their relationship with FIs. The European Data Protection Board (EDPB), which is responsible for giving guidance about the GDPR, states in its Guidelines¹¹⁴ that a CCSP can be considered a data processor if a financial institution decides to make use of the CCSP to store personal data concerning its customers. In contrast, if the CCSP processes personal data for its own purposes, then it can be considered a data controller.¹¹⁵ GDPR imposes cybersecurity responsibilities on undertakings where they are data controllers and processors of personal data. When CCSPs are considered data controllers or processors, they are responsible for complying with the GDPR and can be subject to oversight by SAs according to Art. 51 of the GDPR. The extensive powers of SAs are granted to ensure the protection of fundamental rights in particular the right to data protection. These powers include carrying out investigations, obtaining access to any premises of the controller and processor or issuing warnings as well as imposing monetary fines.¹¹⁶ Due to the risk arising out of the use of CCSPs, national SAs, in coordination with EDPB, started a "coordinated enforcement action" against the use of cloud-based services by the public sector" (CEF) in 2022.¹¹⁷ 22 SAs investigated public sector cloud use in 2022. The CEF was implemented nationally in different ways including fact-finding exercises, formal enforcement investigations, or follow-up to ongoing formal

investigations.¹¹⁸ While the CEF is focused on the public actors, it is possible to extend these actions to the CCSPs as the processors. This enforcement action initiated by SAs shows the importance of coordination in the case of overlapping oversight between the GDPR and DORA.

3.2.2. Why is overlapping oversight problematic?: The *ne bis in idem* principle as an evaluation criterion

In the context of implementing the concurrent supervisory and enforcement frameworks outlined in the NIS 2 Directive, the GDPR, and DORA, it is important to consider the role attributed to the *ne bis in idem* principle as established in Art. 50 of the CFREU.

This principle stipulates that "no one shall be liable to be tried or punished again in criminal proceedings for an offence for which he or she has already been finally acquitted or convicted within the Union in accordance with the law".¹¹⁹ The principle of *ne bis in idem* prohibits the replication of both legal proceedings and penalties of a criminal nature for the same acts committed by the same person.¹²⁰

The prohibition arising from the *ne bis in idem* principle also applies to administrative proceedings or penalties that have a criminal nature according to the case law of the Court of the European Union (CJEU). Concerning the evaluation of whether the proceedings and penalties under consideration in the primary proceedings possess a criminal character, it is evident from the case-law of the CJEU that three criteria hold significance in the context of such evaluation. There are three factors to consider in determining the classification of an offence: the legal classification under national law, the intrinsic nature of the offence, and the severity of the penalty that the individual may face.¹²¹

The scope of the application of Art. 50 of the Charter is not restricted solely to proceedings and penalties that are officially categorized as "criminal" according to national law. Instead, it encompasses proceedings and penalties that possess a criminal nature based on the two additional criteria, regardless of their classification under domestic law.¹²² Concerning the second criterion about the inherent nature of the offence, it is necessary to determine whether the penalty in question

¹¹⁸ *ibid.*

¹¹⁹ See the literature on the *ne bis in idem* principle, Pieter Van Cleynenbreugel, 'BPost and Nordzucker: Searching for the Essence of Ne Bis in Idem in European Union Law: ECJ 22 March 2022, Case C-117/20, BPost v Autorité Belge de La Concurrence Case C-151/20, Bundeswettbewerbshörde v Nordzucker AG e. a.' (2022) 18 European Constitutional Law Review 357; Alessandro Rosano, 'Ne Bis Interpretatio In Idem? The Two Faces of the Ne Bis In Idem Principle in the Case Law of the European Court of Justice' (2017) 18 German Law Journal 39; Bas van Bockel (ed), *Ne Bis in Idem in EU Law* (Cambridge University Press 2016) <<https://www.cambridge.org/core/books/ne-bis-in-idem-in-eu-law/1014B2F6896662EDFB82AFF008FD1E2D>> accessed 27 March 2022; Max Vetzo, 'The Past, Present and Future of the Ne Bis In Idem Dialogue between the Court of Justice of the European Union and the European Court of Human Rights: The Cases of Menci, Garlsson and Di Puma' (2018) 11 Review of European Administrative Law 55.

¹²⁰ CJEU, *bpost SA v Autorité belge de la concurrence (C-117/20)*, EU:C:2023:236, para. 24 and the case-law cited.

¹²¹ CJEU, *MV-98 v Glavna direkcija 'Fiskalen kontrol' pri Tsentralno upravljenie na Natsionalna agentsia za prihodite (C 97/21)*, EU:C:2023:371, para. 38 and the case-law cited.

¹²² *Ibid.*, paragraph 41 and the case-law cited.; See also the analysis of this issue in the literature, Giulia Lasagni and Sofia Mirandola, 'The European Ne Bis in Idem at the Crossroads of Administrative and Criminal Law' [2019] *eu crim* <<https://doi.org/10.30709/eu crim-2019-009>>.

¹¹² *Ibid.* Art. 32(4).

¹¹³ One of the underlying objectives of the GDPR is to ensure the free flow of personal data while protecting the right to data protection recognised in Art. 8 of the EU Charter. To meet this objective, GDPR imposes cybersecurity responsibilities on undertakings where they are data controllers and processors in relation to personal data.

¹¹⁴ 'Guidelines 07/2020 on the Concepts of Controller and Processor in the GDPR | European Data Protection Board' <https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-072020-concepts-controller-and-processor-gdpr_en> accessed 4 February 2023.

¹¹⁵ *ibid.*

¹¹⁶ Art. 58 of the GDPR.

¹¹⁷ 'Coordinated Enforcement Action, Use of Cloud-Based Services by the Public Sector | European Data Protection Board' <https://edpb.europa.eu/our-work-tools/our-documents/report/coordinated-enforcement-action-use-cloud-based-services_public_en> accessed 4 February 2023.

serves, among other things, a punitive objective, irrespective of its concurrent aim of deterrence.¹²³ Criminal penalties inherently serve the dual purpose of punishing and deterring unlawful conduct. In contrast, it should be noted that a measure that solely aims to rectify the harm resulting from the offence in question does not possess criminal characteristics.¹²⁴ When considering the third criterion, which pertains to the severity of the measures in question in the primary proceedings, it is important to note that the severity is assessed based on the maximum potential penalty outlined in the relevant provisions.¹²⁵ Regarding the severity of the penalty, the CJEU considers EUR 5 million as a severe penalty in its judgement in the *Volkswagen* case.¹²⁶ In the same case, the CJEU found that the interpretation of Art. 50 of the Charter suggests that a fine imposed on a company by the national consumer protection authority for unfair commercial practices, even if it is considered an administrative penalty under national legislation, should be considered a criminal penalty under the provision if it serves a punitive purpose and carries significant severity. It shows a broad understanding of proceedings and penalties that have a criminal nature.

The application of the principle *ne bis in idem* is contingent upon two conditions, as evident from the case-law.¹²⁷ Firstly, there must exist a prior final decision, referred to as the 'bis' condition. Secondly, both the prior decision and the subsequent proceedings or decisions must pertain to the same facts, known as the 'idem' condition. With respect to the condition referred to as 'bis,' for a judicial decision to be considered as having rendered a definitive judgement on the facts that are the subject of subsequent proceedings, the decision must have not only attained finality but also have rendered after a determination on the merits of the case.¹²⁸ While it is indeed accurate that the application of the *ne bis in idem* principle assumes the presence of a previous conclusive ruling, it does not automatically imply that the subsequent rulings barred by this principle must exclusively be those made after the aforementioned prior final decision. When a conclusive decision has been made, the aforementioned principle prohibits the initiation or continuation of proceedings concerning identical facts.¹²⁹

Regarding the 'idem' condition, in accordance with established with the case-law, the pertinent standard for determining the presence of the same offence is the congruity of the material facts.¹³⁰ This refers to the existence of a specific set of circumstances that are inherently interconnected and have led to the ultimate acquittal or conviction of the individual in question. Hence, it is evident that the imposition of multiple criminal penalties for the same set of circumstances through separate legal proceedings is explicitly proscribed by Art. 50 of the Charter. Furthermore, it is based on the jurisprudence of the Court that the categorization of the facts and the legal interest safeguarded under national laws are not significant in determining the presence of the

identical offence.¹³¹

Art. 52 of the Charter allows for the limitation of the *ne bis in idem* principle as long as the limitation respects the essence of the principle and meets the criteria of legality, necessity and proportionality.¹³² In specific circumstances, duplicative proceedings and penalties may be permissible without violating this principle, particularly when they serve distinct legitimate objectives of the general interest or protect the rights and freedoms of others.

There are three conditions to ensure the necessity and proportionality of the limitation that allows for duplication of the proceedings.¹³³ The first one is such duplication is acceptable if it involves different legislation targeting different aspects of the offence, ensuring the overall burden on the person concerned is not excessive. Second is that clear, precise rules exist to predict the applicability of such duplication. Third is that these duplicative proceedings should be complementary, conducted in a coordinated manner, and within a proximate timeframe. The overall penalties imposed must correspond to the seriousness of the offences committed, ensuring the burden is strictly necessary and not disproportionate.

Considering the *ne bis in idem* principle and its limitations, Section 3.2.3. and Section 3.2.4 examines to what extent overlapping oversights of CCSPs under DORA with the NIS 2 Directive and the GDPR respect this principle.

3.2.3. Forging a coordinated path with remaining hurdles to respect the *ne bis in idem* principle: Strengthening oversight coordination between final DORA and the NIS 2 Directive

As outlined in Section 3.2.1, DORA and the NIS 2 Directive both anticipate a situation where there is concurrent supervision of CCSPs. The potential for duplicative legal proceedings resulting from the overlapping regulatory oversight of DORA and NIS 2 raises concerns regarding the application of the *ne bis in idem* principle. This principle is applicable because administrative proceedings and penalties outlined in both the NIS 2 Directive and DORA can be considered as having a criminal nature according to criteria established by the case-law of the CJEU. First, both administrative proceedings serve the purpose of penalising the absence of cybersecurity measures. Second the penalties under the NIS 2 Directive and DORA meet the severity requirements considering the amount of maximum monetary fines.

Regarding conditions of *bis* and *idem*, I will give a hypothetical scenario in which a fictitious CCSP, called "CyberGuard" is involved to cast a spotlight on the interplay between overlapping oversight and the principle of *ne bis in idem* under the NIS 2 Directive and DORA. In this scenario, CyberGuard encounters a data breach, compromising critical data held by multiple entities. This breach resonates across sectors including the financial sector, compelling both the competent authority under Art. 32 of the NIS 2 Directive under Art. 31 of DORA to initiate enforcement action and impose a monetary fine. If the issue is CyberGuard's dual classification as an offender within the complex framework of overlapping supervision—its role as both a cloud service provider under the NIS 2 Directive and a CCSP under DORA. The factual elements (*idem* condition) are identical because they are related to the same data breach and its causes, such as a lack of appropriate technical measures. CyberGuard is accused of causing a data breach due to a lack of appropriate security measures.

Assume that the competent authority under the NIS 2 imposed a monetary fine upon CyberGuard, and the decision is final, which means

¹²³ Ibid, para. 42.

¹²⁴ Ibid.

¹²⁵ CJEU, *MV-98 v Glavna direktsia 'Fiskalen kontrol' pri Tsentralno upravlenie na Natsionalna agentsia za prihodite* (C 97/21), para. 46.

¹²⁶ CJEU, *Volkswagen Group Italia SpA, Volkswagen Aktiengesellschaft v Autorità Garante della Concorrenza e del Mercato* (C-27/22), EU:C:2023:663, para. 54.

¹²⁷ CJEU, *bpost SA v Autorité belge de la concurrence* (C-117/20), para. 28. See in-depth analysis of the case, Cleynenbreugel (n 119).

¹²⁸ Ibid, para. 20.

¹²⁹ CJEU, *Volkswagen Group Italia SpA, Volkswagen Aktiengesellschaft v Autorità Garante della Concorrenza e del Mercato* (C-27/22), para. 59.

¹³⁰ CJEU, *bpost SA v Autorité belge de la concurrence* (C-117/20), para. 33.

¹³¹ Ibid., para. 34.

¹³² CJEU, *Volkswagen Group Italia SpA, Volkswagen Aktiengesellschaft v Autorità Garante della Concorrenza e del Mercato* (C-27/22), para. 88-98.

¹³³ Ibid., para. 96.

that the *bis* condition is met. In that case, can the Lead Overseer or the competent authority under DORA continue its proceedings to impose a penalty or stop the proceedings to respect the *ne bis in idem* principle? The response to this question requires the assessment of whether the limitation to *ne bis in idem* principle under DORA and the NIS 2 Directive respects the three conditions mentioned above. First, DORA and the NIS 2 Directive allow for overlapping oversight and possible duplication of proceedings as they might serve distinct legitimate objectives of general interest. It can be stated that although the underlying general interest is cybersecurity under these two pieces of legislation, they have a complementary nature in the sense that while the continuity of essential services is an objective of the NIS 2 Directive, DORA aims for financial stability. The second criterion is the precise rules regarding the overlapping of oversight and enforcement. They foresee the overlapping oversight. The third element is that a judicious coordination framework becomes paramount. It should delineate the roles, responsibilities, and mechanisms for collaboration between the relevant authorities to prevent the imposition of excessive or disproportionate punitive measures, such as duplicative administrative fines, which could contravene the spirit of the *ne bis in idem* principle. By elucidating a clear roadmap for the orchestration of supervisory actions and enforcement measures, the overlapping supervision regime can navigate the intricacies of regulatory harmonisation and uphold the *ne bis in idem* principle's fundamental tenets. Then, it ultimately fosters a more effective and equitable regulatory environment in the realm of cybersecurity oversight.

I acknowledge that the proposed DORA was not fully silent on the relationship between DORA and the NIS 2 Directive concerning the oversight of the CCSPs, at least in its Recitals to respect the *ne bis in idem* principle. However, the final version of DORA respects *ne bis in idem* principle to a great extent. Recital 19 of the proposed DORA acknowledges this relationship and states that the oversight of CCSPs under DORA complements the supervision under the NIS 2 Directive. In addition, Art. 42 of the proposed DORA sets forth the coordination between competent authorities under the NIS 2 Directive and DORA. However, this coordination was limited to general coordination regarding cybersecurity matters rather than the overlapping oversight of critical ICT service providers.

The final DORA addresses the problem of overlapping oversight and supervision regimes to a great extent to ensure respect for the *ne bis in idem* principle under two respective regimes (NIS 2 Directive and DORA). First, Recital 20 of DORA, which was Recital 19 in the proposed DORA, mentions that oversight established by DORA for CCSPs is complementary to the oversight in the NIS 2 Directive for CCSPs. The complementary nature and coordination in the overlapping supervision are established on four novel aspects during the legislative discussions in the final DORA. The first aspect is regarding the structure of the oversight forum. In the final DORA, a representative from the competent authority under the NIS 2 Directive to the Oversight Forum is added in Art. 32(4)(e) of DORA. The second novel aspect is related to the exercise of the power of Lead Overseers. According to Art. 32(2)(b) of DORA, the Lead Overseer shall consult with the competent authorities under the NIS 2 Directive to avoid the imposition of double technical and organizational measures. The third novel aspect is related to the follow-up by competent authorities. In Art. 42(5), competent national authorities under DORA, before taking a decision, should consult the competent authorities under the NIS 2 Directive that are responsible for the oversight of CCSPs voluntarily. Similarly, Art. 42(8) stipulates that when the national competent authority decides on the termination or suspension of a contract with CCSPs, the national competent authorities should take the opinion of the national competent authority of the NIS 2 Directive into account while deciding on the suspension of contracts. The fourth novel aspect is related to the general coordination framework between ESAs, and national competent authorities within DORA and the NIS 2 Directive. Art. 47(1) adds that the ESAs and competent authorities within DORA have a general coordination framework with the competent authorities under the NIS 2 Directive for the CCSPs. More

importantly, Art. 47(3) stipulates that those national competent authorities within DORA can request technical assistance and advice from the national competent authorities under the NIS 2 Directive and establish general cooperation arrangements between these authorities. In addition, Art. 47(4) requires the coordination of supervision and oversight activities such as on-site inspections, and the exchange of information between these authorities to avoid duplicate information requests or on-site inspections.

The coordination between respective authorities in the NIS 2 Directive and DORA is ensured by these four novel aspects that are inserted during legislative discussions. Thus, DORA's final version meets the coordination between different competent authorities to a great extent to respect the *ne bis in idem* principle. However, I maintain that while the initial goal of coordination has been met to a great extent, there is still room for improvement in terms of the imposition of monetary fines to ensure that there is no excessive duplicative monetary fine in the event of non-compliance with the specific recommendations of the Lead Overseer. Indeed, the discretion of imposing periodic penalties is already limited by determining the criteria while imposing the amount of periodic penalty in Art. 35(8) of DORA. However, it does not explicitly require that the Lead Overseer shall take into account the monetary fine that is imposed by competent authorities under the NIS 2 Directive for incompliance with the Directive, assuming that the competent authority has already imposed a monetary fine upon the same CCSP. If this fact is not taken into account, this might result in an excessive burden upon the CCSP, which might prejudice the proportionality in the case of duplicative proceedings and enforcement.

3.2.4. *Lost in the shuffle?: Examining the oversight coordination between DORA and the GDPR in the light of the ne bis in idem principle*

In the hypothetical scenario where CyberGuard faces a data breach affecting both personal data security and broader cybersecurity, the overlap of oversight under the GDPR and DORA presents a complex challenge regarding the *ne bis in idem* principle. The principle's application extends to administrative proceedings with a criminal nature, as interpreted by the CJEU. The GDPR and DORA operating concurrently could result in CyberGuard facing investigations and penalties from both SAs under the GDPR and Lead Overseer and competent authorities under DORA for the same incident. This raises concerns about redundant oversight and inconsistent penalties, potentially contravening the *ne bis in idem* principle. This overlap might lead to the same facts being sanctioned multiple times, undermining regulatory consistency and effectiveness. The CJEU's criteria for evaluating whether proceedings and penalties have a criminal character — legal classification, intrinsic nature, and penalty severity — become relevant in this context. Similar to DORA, The administrative proceedings and subsequent monetary penalties under the GDPR, even if labeled as administrative, have a criminal nature since they serve a punitive purpose¹³⁴ and carry significant severity.¹³⁵ This broad interpretation underscores the complexity of applying the *ne bis in idem* principle in the scenario where CyberGuard is subjected to multiple proceedings and penalties for the same data breach.

In the given scenario, the two conditions of the *ne bis in idem* principle can be met. Should CyberGuard be subjected to multiple penalties with a final decision (the “bis” condition) for the same breach (the “idem” condition)? Thus, this type of overlap under the GDPR and DORA necessitates a judicious alignment with the *ne bis in idem* principle, as expounded in the preceding discourse. Despite the overlapping of the

¹³⁴ W Gregory Gregory Voss and Hugues BOUTHINON-DUMAS, ‘EU General Data Protection Regulation Sanctions in Theory and in Practice’ (2021) 37 Santa Clara Computer and High Technology Law Journal 1.

¹³⁵ *ibid.*

oversight framework of CCSPs under the GDPR and DORA, neither the proposed nor final DORA addresses the issue of potential duplicative oversight with national SAs in GDPR by establishing a coordination framework. The reason for this is most likely that GDPR is viewed as a personal data regulation rather than a cybersecurity regulation in and of itself. I do not agree with this assumption due to the following reasoning. Cybersecurity responsibilities under Arts. 32, 33 and 34 of the GDPR impose similar responsibilities by specifically focusing on personal data.¹³⁶ As personal data security is part of broader cybersecurity responsibilities, there is a need for a coordinated framework to respect *ne bis in idem* principle. Interestingly, the NIS Directive, which is the previous version of the NIS 2 Directive exhibited a similar lack of coordination framework. The NIS Directive does not provide for cooperation between national SAs under GDPR and national competent authorities under the NIS Directive.¹³⁷ This could have led to duplication of oversight. In the NIS 2 Directive, one detailed provision in Art. 35 titled “Infringements involving a personal data breach” covers how the duplication of supervision and enforcement shall be carried out in the case of a personal data breach. As a result of implementing a coordination framework, duplicative oversight will be avoided in the NIS 2 Directive. In contrast to the NIS 2 Directive, it appears that DORA takes the NIS Directive approach, which fails to achieve the goal of avoiding duplicative enforcement. As a result, there is a risk of duplicative oversight and monetary fines in the event of noncompliance if the Lead Overseer under DORA does not coordinate its enforcement with national SAs. In particular, when national SAs use their powers to oversee CCSPs per Arts. 55 and 56 of the GDPR.

To avoid the Lead Overseer’s duplicative oversight of CCSPs, I propose that the Lead Overseer should coordinate with national SAs that oversee the activities of CCSPs regarding the GDPR. For the coordination framework, the Lead Overseer may benefit from the structure of coordination provided for the competent authorities in the NIS 2 Directive and under Art. 47 of DORA. Otherwise, it is possible to have redundant administrative measures that are not proportionate,¹³⁸ which prejudice the *ne bis in idem* principle.

3.2.5. Recommendations for future policy directions in the overlapping oversight in the intersection of cybersecurity and data protection in the financial sector

After examining the new oversight regime for CCSPs, I argue that having an additional oversight framework for CCSPs is questionable for three reasons. First, the NIS 2 Directive already increases oversight of CCSPs, recognizing their importance in the economy as a whole. The absence of financial sector oversight does not imply that these providers are not subject to oversight by various authorities. These service providers are already subject to oversight by SAs under the GDPR in addition to the competent authorities under the NIS 2 Directive. Second, these authorities have more experience with cloud service oversight than competent authorities in the financial sector or ESAs. Third, the underlying goal of DORA’s additional supervision of CCSPs is similar to the goal of the NIS 2 Directive. The Directive’s overarching goal is to ensure the continuity of essential services. Systemic risk concerns about

the use of CSPs stem from the possibility of CSPs’ services being disrupted. In the case of CSPs, the continuity of essential services includes the goal of ensuring the continuity of services to FIs.

In terms of the oversight framework for CCSPs, I propose two options for policymakers. The first option is to keep the NIS 2 Directive’s national competent authority as the sole overseer of cybersecurity measures for the cybersecurity objective. On two counts, the option should be supported. First, the NIS 2 Directive shall make explicit the systemic risk of CSPs by stating that the systemic impact of CSPs on all sectors, including the financial system should be considered when supervising CSPs’ activities. The second element is to establish collaboration with competent authorities under DORA to consider the systemic impact of CSPs on FIs. The systemic risk created by cloud services can be mitigated if the national competent authority under the NIS 2 Directive coordinates its oversight activities with financial authorities and takes the financial stability concerns into account during their oversight.

Alternatively, it is recommended that the EU should contemplate the establishment of a competent authority at the EU level under a cybersecurity legal instrument, as opposed to the sector-specific supervision at the EU level adopted by DORA. Indeed, it is accurate to assert that the establishment of a supervisory body at the EU level is legally unattainable under the current NIS 2 Directive since directives at the EU level do not aim for maximum harmonisation and give discretion for the implementation to the Member States. Given the ongoing efforts towards achieving greater harmonisation in digital space in the EU, it is plausible to anticipate that the forthcoming legal framework of cybersecurity may adopt a regulation instead of a directive. The potential outcome in the form of regulation could involve the creation of a new competent authority at the EU level. DORA supports the potential establishment of an oversight body with jurisdiction at the EU level. Recital 20 of DORA emphasizes the need for the inclusion of cloud computing service providers within the scope of DORA’s Oversight Framework, particularly in situations *where a comprehensive Union-wide framework for digital oversight is lacking*. In other words, if a comprehensive Union-wide framework for oversight of CCSPs exists, there will be no need for sector-specific oversight under DORA. A comprehensive Union-wide framework lies in its potential to mitigate the risk of CCSPs significantly impacting business continuity at a systemic level for all sectors. The significance of the critical role played by the CCSPs in the digital economy and their cross-border nature within the European Union is the reason for this. One primary benefit of implementing oversight mechanisms is the ability to effectively manage various systemic risk factors associated with CCSPs, extending beyond the scope of solely addressing risks related to financial stability. The second benefit is that it alleviates concerns about the possible lack of enforcement of the NIS Directive¹³⁹ or the GDPR against major tech players¹⁴⁰ at the national level.

4. Conclusion

The dynamic nature of financial services, specifically the growing dependence on CSPs has given rise to a range of intricate issues about

¹³⁶ See for the similarities, Alessandro Mantelero and others, ‘The Common EU Approach to Personal Data and Cybersecurity Regulation’ (2021) 28 International journal of law and information technology 297.

¹³⁷ Eyüp Kun, ‘Late, But Not Too Late: Respecting Ne Bis In Idem Principle in the Proposed NIS 2 Directive for Personal Data Breaches (Part 1)’ (CITIP blog, 17 May 2022) <<https://www.law.kuleuven.be/citip/blog/late-but-not-too-late-part-1/>> accessed 4 February 2023.

¹³⁸ Didenko also refers to the problem of duplicative enforcement and supervision in the cybersecurity laws, see Didenko (n 39).

¹³⁹ There is lack of the NIS Directive enforcement at the national level see, ‘Impact Assessment Proposal for Directive on Measures for High Common Level of Cybersecurity across the Union | Shaping Europe’s Digital Future’ <<https://digital-strategy.ec.europa.eu/en/library/impact-assessment-proposal-directive-measures-high-common-level-cybersecurity-across-union>> accessed 30 September 2022.

¹⁴⁰ Irish SA has been criticized because it does not enforce the rules against big tech players including Google, Facebook. See ‘Ireland Frets as Criticism over Big Tech Links Goes Mainstream’ (POLITICO, 16 December 2021) <<https://www.politico.eu/article/ireland-frets-criticism-over-big-tech-links-goes-mainstream/>> accessed 7 February 2023.

operational risk and cyber risk. The convergence of operational risk and cyber risk, particularly in the context of CSPs, has significantly heightened the magnitude of these risks to a systemic extent, capable of instigating economic crises. The focus of FIs on a restricted number of CSPs introduces an augmented level of systemic risk.

Before DORA, the EBA Guidelines recognised the systemic implications of concentration risk related to CSPs. However, there were still notable deficiencies in effectively addressing these risks. The guidelines offer limited guidance and do not provide a comprehensive framework for addressing the systemic implications of CSPs in the financial sector. One of the main obstacles in mitigating concentration risk lies in the inherent complexity of accurately evaluating it. The issue of concentration risk necessitates a comprehensive perspective on the entirety of the financial sector, a task that may prove challenging for individual FIs and national competent authorities. The findings of the ESRB regarding insufficient monitoring of third-party suppliers and supply chains serve to highlight the deficiencies in the existing regulatory framework concerning CSPs. It is evident that the current regulations regarding outsourcing fail to sufficiently address the wider systemic implications associated with the utilisation of CSPs.

In response to these concerns, DORA is adopted to achieve a state of harmonisation in achieving cybersecurity in the financial sector as well as mitigating systemic risk arising out of the use of CSPs, which are considered CCSPs. DORA aims to mitigate the systemic risk via the oversight of CCSPs; however, the new oversight regime brings about new challenges due to the overlapping oversight in the NIS 2 Directive and the GDPR. DORA recognises the correlation between its existence and the NIS 2 Directive. In particular, the final version of DORA establishes a comprehensive coordination framework to respect *ne bis in idem* with some limitations. When it comes to overlapping oversight in the GDPR and DORA, there is a clear lack of coordination framework that effectively mitigates redundant enforcement measures. This gives rise to concerns regarding the possibility of duplicative penalties, which have the potential to undermine the principle of *ne bis in idem*.

Moreover, it is imperative to reassess the necessity of implementing a supplementary oversight regime for CCSPs under DORA. The NIS 2 Directive has been already adopted to enhance the level of supervision over CCSPs, acknowledging their significance within the digital economy. Instead of developing a novel oversight framework dedicated to specific sectors within DORA, it might be more advantageous to improve the collaboration and cooperation among the current oversight

authorities. This approach has the potential to reduce systemic risk while circumventing the intricacies associated with the presence of multiple oversight bodies. As discussed in Section 3.2.5, in an alternative approach, the EU may consider the prospect of establishing a competent authority at the EU level to address cybersecurity concerns, particularly in light of the transnational nature of CCSPs. The establishment of such an oversight body could offer a comprehensive strategy for supervision and implementation, thereby guaranteeing a greater degree of uniformity and efficacy in managing and mitigating systemic risks. This approach would be consistent with the ongoing endeavours to achieve harmonisation of cybersecurity regulations within the EU.

In conclusion, the implementation of DORA marks a notable advancement in acknowledging and tackling the systemic ramifications associated with the utilisation of CCSPs within the financial industry. Nevertheless, it causes new risks regarding the overlapping oversight among DORA, the NIS 2 Directive, and the GDPR. It may prejudice the *ne bis in idem* principle in the absence of a prudent coordination framework and coordination in practice. The resolution of these concerns is critical to ensuring the financial industry's long-term viability and consistency in an increasingly digitalized and interconnected global context.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

No data was used for the research described in the article.

Acknowledgements

I would like to extend my heartfelt gratitude to the referees for their invaluable and constructive feedback. In addition, my thanks go to the organizers of the 2023 Symposium in Cybersecurity Policy at Tufts University, held on 31 March 2023, for the opportunity to present my research. Sharing my findings with fellow researchers and receiving their insightful feedback was instrumental in shaping this article.